

Más allá del taint

Invariantes estructurales y witnesses verificables por máquina para fallas de autorización, ciclos de estado y topologías de confianza

Proyecto MANIFOLD

IR tipada · Lean 4 · GLMY · witnesses Z3

2026

- 1 Una **frontera medida** sobre los priors geométricos en SAST de inyección.
- 2 Una **invariante de autorización**, mecanizada en Lean 4 y hecha operacional (detector BOLA/IDOR + witness de ownership en Z3).
- 3 Evidencia de que la **homología de caminos dirigida** supera a la simetrizada para detectar ciclos destructivos.
- 4 Una **frontera de arbitraje neuro-simbólico** medida.
- 5 Un **análisis de topología de confianza** para IAM / movimiento lateral.

Sistema: una IR tipada, cinco capas

Capa	Estructura	Contribución
Algebraica	función de privilegio $F : V \rightarrow \mathbb{N} + \text{aristas}$ auth	invariante de autorización
Espectral	corte de Fiedler	fronteras de confianza
Topológica	H_1 dirigida GLMY	ciclos de estado
Geométrica	Forman–Ricci κ_F	puentes de privilegio
Formal	Z3 + Lean 4	witnesses verificables por máquinas

Seis adaptadores (Python, Java, binario, OpenAPI, IAM, IIm-agent) $\rightarrow$ un grafo, compartido
Python $\leftrightarrow$ Rust.

C1 — La frontera sobre los priors geométricos

- **Pregunta:** ¿aportan las invariantes espectrales/topológicas/ geométricas información sobre el taint para priorizar inyecciones?
- **Medido en OWASP Benchmark 1.2 (2740 casos):** no.
- taint MRR 0.894 vs. campo fusionado 0.872 ($p = 5 \times 10^{-5}$); espectral 0.496, topológica 0.500 (azar), curvatura 0.376.
- Un servlet plano no tiene esa estructura; el taint ya es casi óptimo allí.
- **Contribución:** una respuesta rigurosa y falsable que redirige el esfuerzo a donde la estructura *sí* es la señal.

C2 — Autorización, mecanizada y operacional

- $F : V \rightarrow \mathbb{N}$, aristas auth $E_A = \{(u, v) : F(u) < F(v)\}$; no_auth_bounded mecanizado en Lean 4.
- Detector BOLA/IDOR: acceso a recurso controlado por el usuario sin puerta.
- **Witness de ownership en Z3**: $\text{SAT}(\text{owner}(id) \neq \text{session})$.
- login_required (autenticación) *no* bloquea BOLA — solo un predicado owner a nivel de objeto lo hace.
- **Datos reales (crAPI)**: 9/9 BOLA/BFLA recuperados, recall 1.0, precisión 0.90; el chequeo de auth-ausente puntúa 0 (todos están autenticados).

- Simetrizar es pérdida en ambos sentidos: un 2-ciclo colapsa (se pierde), un triángulo relleno se vuelve un ciclo falso.
- GLMY recupera el generador β_1 concreto.
- **Medido (12 grafos de estado):** recall 1.0 / precisión 0.75 vs. no dirigida 0.5 / 0.5.
- H_1 de GLMY = huecos de path-space $\supset$ ciclos de feedback: alto recall, necesaria-no-suficiente.

- El LLM *propone* una spec estructurada; Z3 *decide*.
- **Medido (38 archivos, 29 hallazgos):** acuerdo detección/ranking 0.974 (independiente del LLM); CWE cambia 28% (interpretación).
- Spec-mining (8 fragmentos): 0.5 recall de tokens, 0 alucinación.
- **Contribución:** una arquitectura + su medición, no una afirmación.

- Grafo de identidades y permisos: usuarios, roles, políticas de confianza, servicios.
- **Corte de Fiedler** saca los cruces de frontera de confianza.
- **Forman–Ricci** aísla el puente de privilegio (el pivote del atacante).
- Z3 resuelve la combinatoria de asunción de roles.

Contribución	Resultado
C1 frontera	taint 0.894 vs. campo 0.872 ($p = 5 \times 10^{-5}$)
C2 autorización	crAPI recall 1.0, precisión 0.90, F1 0.947
C3 homología dirigida	0.75/1.0 vs. no dirigida 0.5/0.5
C4 arbitraje	detección/ranking 0.974; CWE 28%
C5 topología de confianza	punto de privilegio $\kappa_F = -1$

Limitaciones (reportadas, no ocultas)

- BOLA/IDOR: una API real + un corpus curado, no un benchmark.
- El detector estructural sobre-aproxima (sanitizado/parametrizado).
- Los witnesses de Z3 valen bajo la semántica *modelada*, no end-to-end.
- El H_1 de GLMY es necesario, no suficiente.

- El rol productivo de las invariantes estructurales en seguridad es la *verificación* de propiedades de autorización, estado y confianza — no la priorización de sinks de inyección.
- Todo sobre una IR tipada, emitiendo witnesses verificables por máquina.

Mapa el artefacto como un espacio — verifica la invariante.